BAŞLANGIÇ FÖYÜ · ARMINOKS SÜT OTOMATI

Makine Profili

Çıktı: Sistem sınırı · kaynaklar · varsayımlar

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Kavram: Bütün laboratuvarlar aynı makine üzerinde işlenir. Önce makinenin sınırı çizilir: **neyi biliyoruz** (üretici kaynağı), **neyi kabul ediyoruz** (ders senaryosu) ve **neyi istiyoruz** (gereksinim). Bu üçü karıştırılırsa analiz, gerçek makine hakkında yanlış iddiaya dönüşür.

Arminoks bağlamı: Arminoks Makina İmalatı ve Pazarlama San. Tic. Ltd. Şti.'nin süt otomatı. Atama listesinde no 35, SAMİB kuruluş grubu. Bilgiler üreticinin kamuya açık broşüründen alındı. Firmayla iletişim kurulmadı; makine üzerinde tarama veya test yapılmadı.

İşaretler

Kod	Anlamı
D01–D08	Üretici kaynağında belirtilen özellik (doğrulanmış bilgi)
V01–V10	Ders senaryosu için yapılan kabul; sahada doğrulanmalı
H01–H07	Önerilen koruma gereksinimi (LAB4); uygulanmış sayılmaz
LAB kodları	SF-01–04 işlevler (LAB1) · Z0–Z5 bölge, C01–C07 geçiş, G01–G05 kapı, A/W/U/AK/B/F envanter (LAB2) · R-01–04 senaryo (LAB3) · KT01–07 test, uygulanmadı (LAB4) · VD-01 karar (LAB5)
T · K	Kaynaklar: öğretmen dosyaları ve dış kaynaklar (bu föyün sonu)

Üretici broşüründe belirtilen özellikler

Kod	Özellik	Kaynak
D01	AISI 304 paslanmaz kabin, 220 V besleme	K01, s.5
D02	0–4 °C soğutma aralığı, panelden sıcaklık takibi	K01, s.5
D03	50 / 100 / 200 / 400 L seçenekleri; tanklı tipte 200 / 400 L	K01, s.5–6
D04	Programlanabilir karıştırma, kendinden emişli dolum pompası	K01, s.5
D05	Dokunmatik panel; satış geçmişi için USB	K01, s.5
D06	SMS bilgi paylaşımı modülü (opsiyon)	K01, s.5
D07	Her dolumdan sonra dolum ünitesinin otomatik yıkanması	K01, s.5
D08	Ödeme ve barkod seçenekleri	K01, s.4–6

Broşürün s.3'ündeki ayrı dolum makinesi ve soğutma tankı bu otomata ait sayılmadı; oradaki "kapak açılınca durma" özelliği de otomata aktarılmadı. 0–4 °C bir ürün özelliğidir; gıdanın uygunluğunu tek başına belirleyen sıcaklık-süre ölçütü değildir.

Çalışma modeli

Süt tankta soğutulur ve karıştırılır; satış talebinde pompa ile dolum yapılır; her dolumdan sonra yıkama sırası çalışır. Analiz panel, kontrolör, karıştırıcı, pompa, soğutma, yıkama, USB ve bakım yollarını kapsar. Ürün envanterine robot, yapay zekâ, SCADA, pastörizasyon veya bulut hizmeti **eklenmedi**. LAB7'deki kamera/YZ zinciri yalnız eğitim senaryosudur.

Ders senaryosu kabulleri

Kod	Kabul	Geçerli değilse
V01	Panelin bağlı olduğu programlanabilir bir kontrolör var; marka/sürüm bilinmiyor	Model gerçek kontrol yapısına göre güncellenir
V02	Bakım sırasında karıştırıcıya erişilebilir	R-01/R-04 yaralanma zinciri yeniden değerlendirilir
V03	Yıkama ve satış aynı dolum bölümünde farklı çalışma durumlarıdır	Yıkama–satış ilişkisi gerçek akışa göre değişir
V04	Sıcaklık ölçümü ve satış izni yazılımda değerlendirilir	Bağımsız kontrol varsa R-02 zincirine eklenir
V05	LAB2–4 için bir bakım bilgisayarı ve sürekli açık uzak servis yolu var	Uzak erişim yoksa bu yol temel kurulumdan çıkar
V06	V05 yolunda değiştirilmemiş varsayılan parola ve geniş yazma yetkisi var	L/E puanları yeniden verilir
V07	Yerel servis hesabı paylaşılıyor; USB'den servis paketi yüklenebilir	USB yalnız veri aktarıyorsa R-03'ün yükleme zinciri düşer
V08	Kapak/yeniden başlama denetimi bugün normal kontrol yazılımında	Bağımsız koruma varsa R-01/R-04 zinciri değişir
V09	Yıkama tamamlanma bilgisi satış iznini etkileyen bir kontrol koşulu	Gerçek yöntem farklıysa SF-04 ve R-03 güncellenir
V10	LAB5'in Component X v2.4 kaydı föyün temsili girdisidir	Gerçek kayıtlar ayrı raporda incelenir

V05–V08 üreticide bulunmuş açıklar **değildir**. SMS bildirimi internetten programlama kanıtı, USB satış kaydı da program yükleme kanıtı sayılmaz. Kimyasal veya sıcak yıkama kabul edilmedi. Ayrı bir Safety PLC kurulu olduğu söylenmez; gereken koruma LAB4'te gereksinim olarak tanımlandı. Saha ve devre bilgisi olmadığından PLr/SIL atanmadı.

Analizin değişeceği durumlar

- **Uzak erişim yoksa:** R-01'in uzak yolu çıkar; yerel ekran, USB ve bakım yolları kalır.
- **USB yalnız satış verisi aktarıyorsa:** R-03'ün program yükleme yolu geçersizleşir.
- **Karıştırıcıya erişim mümkün değilse:** mekanik senaryolar (R-01, R-04) yeniden puanlanır.
- **Gerçek temizlik ve ürün verisi farklıysa:** biyolojik senaryolar (R-02, R-03) gıda sorumlusuyla yeniden değerlendirilir.
- **Kontrolör ve yazılım sürümleri sahada okunursa:** LAB5 kararı gerçek kayıtlarla güncellenir.

Yazılım araştırması (06.11.2026)

Üretici fotoğraflarında LS panel logosu görüldü; eXP20 ailesi yalnız **görsel aday**. Tam model ve kurulu işletim sistemi/runtime/PLC sürümü doğrulanmadı. XP-Builder ve XP-Remote 3.90.2221, XP-Manager 3.90.241211 üreticinin yayımladığı paket sürümleridir; otomatta **kurulu** sürümler değildir. Koşullu CVE adayları ve sürüm okuma adımları: teknik rapor · yazılım/CVE envanteri.

Kaynaklar

ID	Kaynak	Kullanım
T01	Öğretmenin `2.1. lab_foyleri_genel.pdf` föyü	s.2–8: LAB1–7 görevleri
T02	Öğretmenin `2.2 lab_foyleri_paketpro.pdf` föyü	Makineye uyarlama örneği
T03	Öğretmenin `LAB3.pdf` ders notu	Slayt 23–33: ölçek; 43: görev; 46: tartışma
K01	Arminoks süt otomatı broşürü	s.4–6: süt otomatı özellikleri
K02	NIST SP 800-82 Rev.3	OT güvenliği genel rehberi
K03	Regulation (EU) 2024/2847 — CRA	LAB6 bildirim süreleri (Madde 14)

Bu föyün çıktısı **sistem sınırı ve varsayım listesi** → bütün Evidence Pack başlıklarının ortak dayanağıdır. Durum: **Taslak**.

LABORATUVAR 1 · ARMINOKS SÜT OTOMATI

Safety Architecture

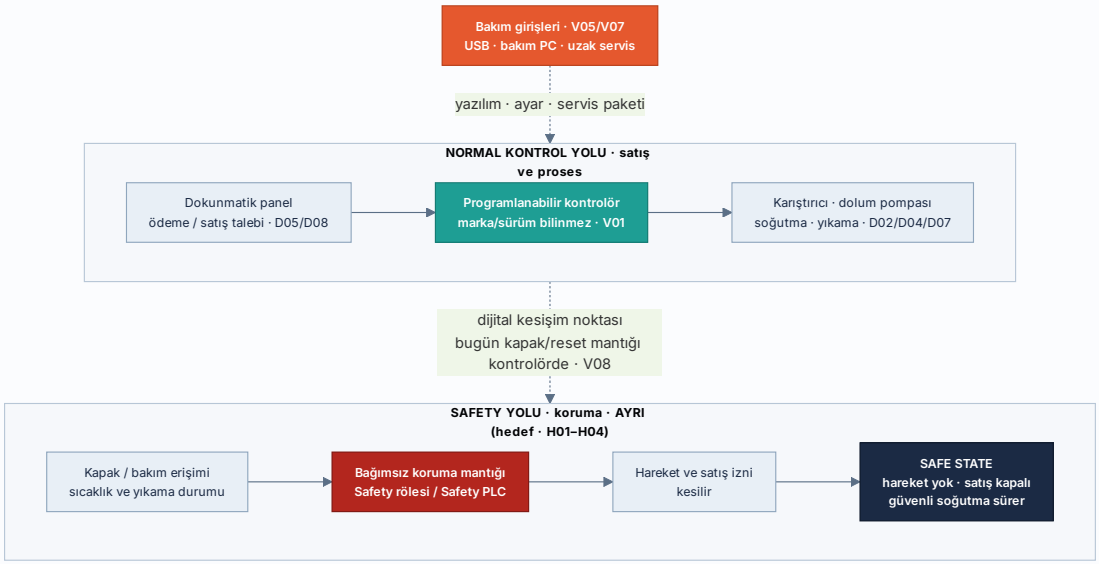
Çıktı: Safety Function Map

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Kavram: Emniyet fonksiyonu, insanı koruyan fonksiyondur ve **ayrı bir safety yolunda** yaşar (E-stop → Safety PLC → STO). Gerekli güvenilirliği (PLr/SIL) riskle orantılıdır — ve bu güvenilirlik, **dijital bir konfigürasyona** bağlıdır.

Arminoks bağlamı: Süt soğutulur (0–4 °C), programlanabilir karıştırıcıyla karıştırılır, kendinden emişli pompayla dolum yapılır ve her dolumdan sonra dolum ünitesi otomatik yıkanır (D02, D04, D07). Broşürde E-stop veya Safety PLC bilgisi yoktur. Bu yüzden şemanın safety yolu **doğrulanmış devre değil, hedef koruma modelidir** (V01–V04, V08–V09). Burada iki tür zarar var: **bakımcının eli** (karıştırıcı, pompa) ve **tüketicinin sağlığı** (uygunsuz sıcaklık veya yıkama sonrası satış).

Safety Function Map



Kırmızı kutu ve alttaki yol, **safety-related control system (SRCS)** hedefidir. Turuncu kutu dışarıdan erişilebilen dijital kapıdır. Kesikli oklar, siber müdahalenin koruma zincirine dokunabildiği yerleri gösterir.

Görev — sırayla cevaplayın

1 **Bu makinede tehlike nedir? İnsan neyden zarar görür?**

- **Karıştırıcı ve pompa (bakım sırasında):** Tank kapağı açıkken dönen karıştırıcıya el/kol kaptırma; pompa ve valf bölgesinde sıkışma. Ağır yaralanma olabilir (V02).
- **Beklenmedik yeniden çalışma:** Enerji dönüşü veya reset sonrasında, kişi içerideyken hareket başlaması (V08).
- **Tüketici sağlığı:** Sıcaklığı uygun olmayan ya da yıkaması tamamlanmamış dolum hattından süt satılması, uygun koşullarda ciddi biyolojik zarar doğurabilir (D02, D07, V09).
- **İkincil:** 220 V besleme (D01), ıslak zeminde kayma, yıkama suyu.

En riskli an, **bakımcının tank veya dolum ünitesine müdahale ettiği ve makinenin uzaktan (V05) ya da otomatik sırayla yeniden çalışabileceği** andır.

2 Safety function (emniyet fonksiyonu) hangisidir?

ID	İşlev	Güvenli tepki	Tür
SF-01	Karıştırıcıya erişim koruması	Kapak/erişim açıkken hareket yok; duruş olmadan erişim yok	Makine emniyeti
SF-02	Sıcaklık ve ürün uygunluğu kilidi	Ölçüm geçersiz veya sapmışsa satış kapalı	Gıda koruması
SF-03	Beklenmedik yeniden başlamayı önleme	Reset veya enerji dönüşü hareket başlatmaz	Makine emniyeti
SF-04	Yıkama–satış ayrımı	Yıkama bitmeden veya durum belirsizken satış yok	Gıda koruması

SF kodları LAB'lar arasında iz sürmek içindir. Dördünün de **sertifikalı emniyet fonksiyonu** olduğu söylenmez. SF-02/SF-04 ürün koruma kilitleridir, makine emniyeti standardının kapsamı ayrıca değerlendirilir.

3 Safety-related control system nerede? Şemada işaretleyin.

Şemadaki **kırmızı kutu ve SAFETY YOLU** (kapak/erişim girişi → bağımsız koruma mantığı → hareket ve satış izninin kesilmesi) SF-01/SF-03 için SRCS hedefidir. Bugünkü varsayımda (V08) bu mantık normal kontrolörün yazılımında duruyor. Bu yüzden şemada **dijital kesişim noktası** olarak işaretlendi.

4 Normal PLC ile Safety PLC farkı nedir?

	Normal PLC / kontrolör	Safety PLC / safety rölesi
Amaç	Satış, dolum, karıştırma, yıkama sırası	İnsanı koruyan fonksiyon ve güvenli arıza tepkisi
Arıza davranışı	Tanımlı değil; donabilir, yanlış çıkış verebilir	Kendini sınar, arızada güvenli duruma geçer
Yapı	Tek kanal	Çift kanal, çapraz kontrol, sertifikalı yazılım bloğu
Değiştirme	Bakım aracıyla kolayca	Yetkili, imzalı/parola korumalı, yeniden doğrulama ister

Ayrı cihaz ya da ayrı IP adresi **tek başına bağımsızlık sağlamaz**. Aynı bakım aracı ve hesap ikisine de yazabiliyorsa koruma gene dijital olarak aşılabilir.

5 PLr / SIL neden var? Bu fonksiyon için neden önemli?

PLr (ISO 13849-1) ve SIL (IEC 62061), bir emniyet fonksiyonunun **ne kadar güvenilir olması gerektiğini** riskle orantılı biçimde belirler: yaralanma ne kadar ağır, tehlikeye ne sıklıkla girilir, kaçınma mümkün mü? SF-01'de bakımcı tanka elini sokacağı için arızada da korumanın sürmesi gerekir. Devre, kullanım sıklığı ve tepki süresi bilinmediği için **PLr/SIL değeri atanmadı**. LAB3'teki S=3 puanı bir PLr karşılığı değildir.

6 Safe state (güvenli durum) nedir?

- **Hareket:** Karıştırıcı ve pompa durmuş, **yeniden başlaması engellenmiş**.
- **Satış:** Satış ve dolum kapalı; panel nedenini gösterir.
- **Soğutma:** Güvenli soğutma **sürer**. Her şeyi kapatmak sütü bozar ve ikinci bir gıda riski yaratır.
- **Bakım:** Kapak kapatıldı diye hareket başlamaz; ayrı yerel başlatma gerekir. Bakımda enerji izolasyonu (kilitle-etiketle) ayrıca uygulanır.

7 Safety function hangi dijital bağımlılıklara sahip?

- Kontrolör programındaki **kapak / reset mantığı** (SF-01, SF-03 · V08)
- **Sıcaklık ölçümü**, alarm eşiği ve satış izni ayarı (SF-02 · V04)
- **Yıkama sırası** ve "tamamlandı" bilgisi (SF-04 · V09)
- Panel uygulaması ve bakım aracı (W01, W03)
- Yükleme yolları: **USB**, bakım bilgisayarı, varsa uzak servis (V05, V07)

8 **Siber müdahale hangi noktadan bu fonksiyonu bozar?**

Dijital kesişim noktası: Kontrolöre program veya ayar yazılabilen yol. Bu yol uzak servis, yerel servis ekranı, USB ile yüklenen servis paketi ya da bakım bilgisayarı olabilir. Buradan kapak/reset mantığı değiştirilirse SF-01/SF-03, sıcaklık eşiği değiştirilirse SF-02, yıkama sırası değiştirilirse SF-04 bozulur. Ders modelindeki en riskli yol **sürekli açık uzak servis → bakım arayüzü → kontrolör** zinciridir (LAB2 G01/G05, LAB3 R-01).

Ek sorularımız

9 **Hata durumunda her şeyi kapatmak neden bu makinede güvenli değildir?** EK SORU

Tehlikeli hareketi ve satışı durdurmak ile **soğutmayı** durdurmak farklı kararlardır. Soğutma da kesilirse tanktaki süt birkaç saat içinde uygunsuz hâle gelebilir ve bu ikinci bir gıda riskidir. Doğru güvenli durum **fonksiyon bazlıdır**: hareket ve satış kesilir, soğutma güvenle sürer (H07).

10 **Panel normal sıcaklık gösteriyorsa satış yapılabilir mi?** EK SORU

Tek bir ekran değeri yetmez. Ekran, değiştirilmiş yazılımda doğru görünürken ölçüm bozuk olabilir. Satış izni için ölçümün **geçerli** olması (sensör hatası yok), geçmişte eşik dışına çıkılmaması ve yıkamanın tamamlanmış olması birlikte aranır. Kabul eşikleri gıda sorumlusunca belirlenir; burada değer uydurulmadı.

11 **Reset neden "başlat" anlamına gelmemeli?** EK SORU

Reset, koruma hatasının giderildiğini **onaylar**; makineyi çalıştırmaz. Reset'e basıldığında karıştırıcı dönmeye başlarsa, kapağı yeni kapatan ya da hâlâ içeride olan kişi yaralanabilir. Hareket için güvenli koşullar sağlandıktan sonra ayrı bir yerel başlatma gerekir (SF-03).

12 **Emniyet bağımsızlığını nasıl sınarız?** EK SORU

Yetkili bir test düzeneğinde: (1) kapak açıkken normal kontrolörden hareket komutu verilir, hareket **olmamalı**; (2) koruma ayarı uzaktan değiştirilmeye çalışılır, **reddedilmeli**; (3) enerji kesilip geri verilir, hareket **kendiliğinden başlamamalı**. Bunlar LAB4'teki KT01/KT03/KT06 testleridir; bu çalışmada uygulanmadı.

Varsayımlar

V01–V04 ve V08–V09 kullanıldı (Makine profili). Kapak/erişim korumasının gerçek tipi, kontrolör modeli ve ayrı bir Safety PLC bulunup bulunmadığı sahada doğrulanmalıdır.

Bu föyün çıktısı **Safety Function Map** → Evidence Pack **EP 03 Safety Functions** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 2 · ARMINOKS SÜT OTOMATI

IEC 62443 Mini Workshop

Çıktı: Zone / Conduit Diagram

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Kavram: Zone = benzer kritiklikteki cihazları bir bölgeye topla. **Conduit** = bölgeler arası her geçişe kontrollü bir kapı. 62443'ün maddesini ezberlemiyoruz — mantığını uyguluyoruz.

Arminoks bağlamı: Föydeki genel varlık listesi (PLC · HMI · Robot kontrolörü · Safety PLC · SCADA istemcisi · Mühendislik istasyonu · Uzak servis erişimi · Ofis ağı) süt otomatına uyarlandı. Otomatta robot ve SCADA yok. Onların yerine karıştırıcı/pompa, soğutma, yıkama, USB ve opsiyonel SMS modülü var. Uzak servis ve yükleme yetkileri ders kabulüdür (V05–V08).

Görev A — varlıkları bölgelere ayırın

Varlık listesi — Arminoks envanteri (EP 01)

ID	Kategori / varlık	Bilgi türü ve sınır
A01	Donanım: dokunmatik panel (HMI)	D05; model bilinmiyor
A02	Donanım: programlanabilir kontrolör (PLC)	V01; ayrı PLC olduğu doğrulanmadı
A03	Donanım: karıştırıcı ve dolum pompası	D04; sürücü/valf yapısı V01
A04	Donanım: soğutma ve sıcaklık ölçümü	D02; sensör tipi V04
A05	Donanım: yıkama ve dolum akışı	D07; çalışma sırası V03/V09
A06	Donanım: USB girişi	D05; yazma yeteneği bilinmiyor
A07	Donanım: bakım bilgisayarı (mühendislik istasyonu)	V05/V08
A08	Donanım: uzak bakım ağ geçidi	V05; SMS modülüyle aynı cihaz değil
A09	Donanım: SMS bildirim modülü	D06 opsiyon; kurulu varsayılmadı
A10	Donanım: kapak ve hareket koruma zinciri (Safety PLC hedefi)	H01/H03; gerçek donanım bilinmiyor
W01–W04	Yazılım: panel uygulaması · kontrol programı · bakım aracı · koruma konfigürasyonu	V01/V05/V08; sürümler bilinmiyor
U01–U03	Hesap: yerel operatör · paylaşılan yerel servis · uzak servis	V06/V07
AK01, AK02	Anahtar: servis kimlik bilgisi · yazılım doğrulama güven kökü	V06; H05 (kurulu iddia edilmez)
B01–B03	Dış bağlantı: uzak servis · USB aktarımı · opsiyonel SMS	V05; D05; D06
F01–F04	Veri akışı: sıcaklık/alarm · satış geçmişi · konfigürasyon/yedek · yıkama tamamlandı bilgisi	D02/D05; V08; V09

1 **Hangi varlıklar aynı bölgede? Bölgeleri adlandırıp gruplandırın.**

Zone	Varlıklar	Kritiklik / hedef sınır
Z0 Dış dünya	Tedarikçi, internet, dışarıdan gelen USB bellek, SMS altyapısı; B01–B03'ün dış uçları	Güvenilmeyen
Z1 İşletme / ödeme	İşletme ağı; varsa ödeme sistemi (D08)	Kontrolöre doğrudan yazamaz

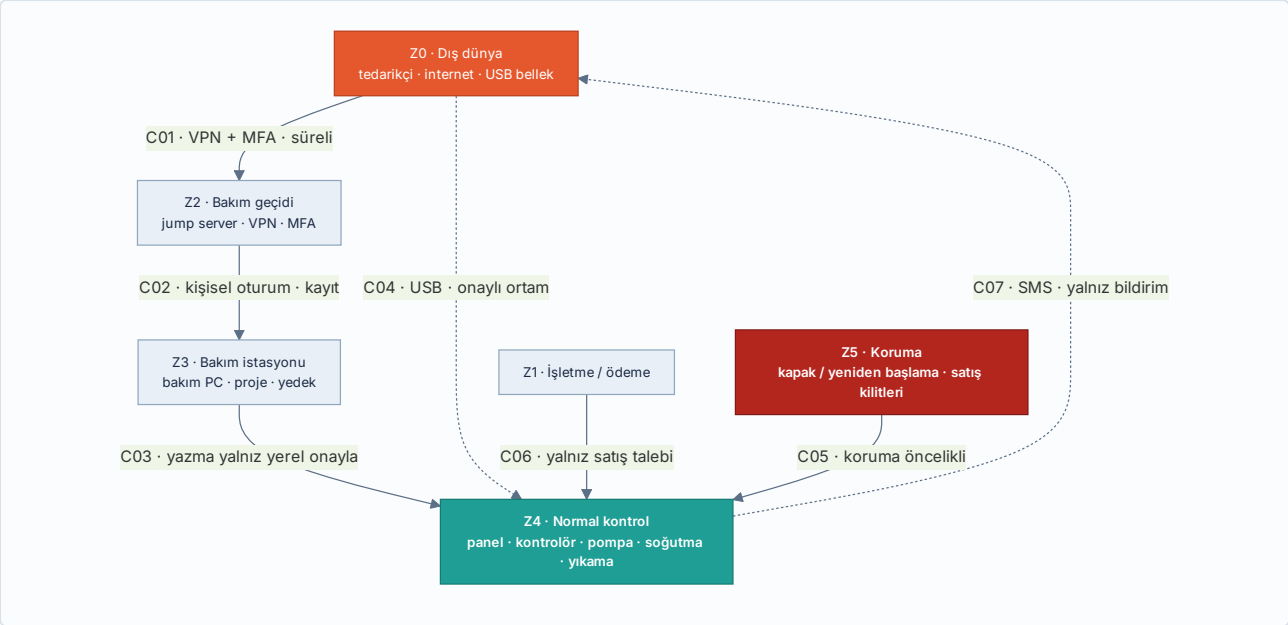
Zone	Varlıklar	Kritiklik / hedef sınır
Z2 Bakım geçidi	A08, U03, AK01 + hedefteki jump server / VPN	Süreli ve kayıtlı giriş
Z3 Bakım istasyonu	A07, W03, F03	Yalnız onaylı değişiklik
Z4 Normal kontrol	A01–A06, A09 (SMS modülü, opsiyon), W01/W02, U01/U02, F01/F02/F04	Satış ve proses
Z5 Koruma	A10, W04, AK02; H01–H04 işlevleri	Normal kontrolden bağımsız

Bu **mantıksal** bölümlendirmedir; her zone ayrı bir fiziksel cihaz gerektirmez.

Giriş kapıları (LAB3 senaryolarında kullanılır):

Kapı	Yol	Envanter / conduit
G01	Uzak servis girişi (sürekli açık kabul edilir)	A08, B01, U03 · C01
G02	Yerel servis ekranı (paylaşılan hesap)	A01, U02 · Z4 içi
G03	USB veri aktarımı	A06, B02 · C04
G04	Servis paketi / bakım projesi (tedarik zinciri)	A07, W03, F03 · Z3
G05	Kontrolör bakım-programlama arayüzü	A02, W02 · C03

G01–G05 ders modelinin yollarıdır (V05–V08); gerçek üründe doğrulanmadı.



2 Safety PLC'yi hangi bölgeye koydunuz — neden?

Z5 Koruma bölgesine, normal kontrolden (Z4) ayrı. Neden: Z4'teki kontrolör ele geçirilse bile Z5'in koruma kararı ve programı **değiştirilememeli**. Gerçek makinede Safety PLC bulunduğu doğrulanmadı; Z5 bir hedef sınırdır. Aynı bakım aracı iki bölgeye de sınırsız yazabiliyorsa ayrı bir zone etiketi tek başına koruma sağlamaz.

3 Bölgeler arası geçişler (conduit) nerede? Her geçişte ne kontrol edilecek?

ID	Geçiş	Kontrol
C01	Z0 → Z2 uzak giriş	VPN, MFA, kişisel hesap; yalnız onaylı bakım penceresinde açık
C02	Z2 → Z3 oturum	Jump server; görev bazlı yetki; oturum ve işlem kaydı
C03	Z3 → Z4 bakım yazması	Varsayılan salt okunur; yazma yalnız yerel onayla; izinli protokol listesi
C04	USB → Z4	Onaylı ortam ve dosya türü; tarama; imzası/kaynağı belirsiz dosya reddedilir
C05	Z5 → Z4 / tehlikeli çıkış	Koruma önceliklidir; Z4 komutu korumayı geçersiz kılamaz
C06	Z1 → Z4 ödeme / satış talebi	Yalnız satış isteği; ödeme ağından programlama yok

ID	Geçiş	Kontrol
C07	Z4 → SMS altyapısı (opsiyon)	Yalnız dışarı bildirim; gelen komut destekleniyorsa yeni risk analizi

Port ve IP numaraları cihaz kılavuzu olmadan uydurulmadı. Tablo kural tanımıdır; kurulmuş bir firewall'un kanıtı değildir.

Görev B — uzak erişim kararı (6 satır)

Karar	Seçenekler	Seçiminiz + nedeni
Aracı?	Doğrudan / Jump server	**Jump server** — tek, kontrollü ve kayıtlı giriş noktası; bakımcı kontrolöre doğrudan ulaşmaz
Tünel?	Açık / VPN	**VPN** — bakım trafiği şifreli ve yalnız tanımlı uca gider; tek başına yetki vermez
Kimlik?	Parola / MFA	**MFA** — çalınan veya varsayılan parola (V06) tek başına içeri sokmaz
Hesap?	Paylaşılan / Kişisel	**Kişisel** — kimin ne yaptığı bilinir; ayrılan kişinin erişimi tek tek kapatılır
Kayıt?	Yok / Tam oturum kaydı	**Tam oturum kaydı** + değişiklik kaydı — kim, ne zaman, neyi değiştirdi
Zamanlama?	Sürekli açık / Varsayılan kapalı	**Varsayılan kapalı** — iş emriyle yerelden açılır, süre bitince kendiliğinden kapanır

Ek sorularımız

4 **Bağlantı noktası açık bir uzak bakım modülü hangi bölgeye düşer; orada kalabilir mi?** EK SORU

Bugünkü kabulde (V05/V06) modül, dış dünya ile kontrolör arasında **denetimsiz bir köprüdür**; fiilen Z0 ile Z4'ü birleştirir. Orada kalamaz. Hedefte Z2 bakım geçidine taşınır ve Z4/Z5'e doğrudan erişim hakkı kalmaz. Otomatta internet hiç yoksa modül hiç eklenmez. (PaketPro föyündeki varyant sorusunun uyarlamasıdır.)

5 **SMS modülü bir internet saldırı yolu mudur?** EK SORU

Bildirim özelliği bunu tek başına kanıtlamaz. SIM/operatör bağlantısı, modülün **gelen komut** kabul edip etmediği ve kontrolöre yazma yetkisi ayrıca bilinmelidir. Temel modelde C07 yalnız dışarı bildirim yapan tek yönlü bir geçiştir. Komut alıyorsa yeni bir conduit olarak yeniden analiz edilir.

6 **Ödeme başarılı olduysa koruma koşulları aşılabilir mi?** EK SORU

Hayır. Ödeme yalnız **satış isteği** üretir (C06). Sıcaklık, yıkama ve bakım kilitleri ayrı izin koşullarıdır. Ödeme alınmış ama sıcaklık geçersizse satış yapılmaz, ödeme iade akışına gider. Koruma kilidi ticari sebeple kaldırılmaz.

7 **Z4 ve Z5'i ayrı VLAN'a koymak yeterli koruma mıdır?** EK SORU

Hayır. VLAN yalnız ağ trafiğini ayırır. Aynı bakım hesabı ya da aynı programlama aracı iki bölgeye de yazabiliyorsa koruma yine değiştirilebilir. Gerekli olan geçiş yetkisi, kimlik, yönetim erişimi ve koruma mantığının **işlevsel bağımsızlığıdır** (LAB4 H05/H06). Renkli bir diyagram tek başına koruma sağlamaz.

Varsayımlar

V01 ve V05–V09 kullanıldı (Makine profili). Gerçek ağ yapısı, uzak erişim yolunun bulunup bulunmadığı ve USB'nin yazma yeteneği sahada doğrulanmalıdır.

Bu föyün çıktısı **Zone / Conduit Diagram** → Evidence Pack **EP 05 Zone & Conduit** başlığına oturur; varlık listesi **EP 01 Asset Inventory**'ye girer. Durum: **Taslak**.

LABORATUVAR 3 · ARMINOKS SÜT OTOMATI

Threat & Risk + Risk Matrix

Çıktı: Risk Register

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Kavram: Senaryo beş parçadır: **kim → hangi kapı → ne yapar → zincir → FİZİKSEL sonuç**. Skor = **L × S × E** (her biri 1–3). Kural: **S=3 ise skor düşük olsa bile senaryo öne alınır** — insana zarar görünür kalır.

Arminoks bağlamı: Kapılar LAB2'deki G tablosundan gelir: uzak servis (G01), yerel servis ekranı (G02), USB (G03), servis paketi / bakım projesi (G04), kontrolör yazma arayüzü (G05). Fiziksel sonuç iki yerde ortaya çıkar: **bakımcının eli** (karıştırıcı) ve **tüketicinin sağlığı** (sıcaklık, yıkama). Puanlar V01–V09 kabullerine dayanır; gerçek makinede bulunmuş bir açık değildir.

Ölçek (LAB3 ders notu)

Puan	L — istismar kolaylığı	S — fiziksel sonuç	E — yolun dışa açıklığı
1	Zor; özel bilgi, fiziksel erişim veya zincir gerekir	Yaralanma yok	Yalnız fiziksel erişim
2	Orta; zayıf veya paylaşılan kimlik bilgisi yeter	Hafif, geri dönüşlü yaralanma	İşletme ağı veya süreli dış erişim
3	Kolay; varsayılan parola, doğrulama yok, hazır araç	Ağır/kalıcı yaralanma, ölüm, ciddi hastalık	İnternet veya sürekli açık dış yol

Görev — üç senaryo kurun ve puanlayın

Föy en az üç senaryo istiyor; bu makinede dört farklı fiziksel zincir çıktığı için dördü de puanlandı.

Senaryo (kim → kapı → zincir → fiziksel sonuç)	L	S	E	Skor	Öncelik
R-01 Fırsatçı dış saldırgan → G01 sürekli açık uzak servis → G05'ten kapak/reset mantığını değiştirir (SF-01/SF-03) → bakımcı tanka elini sokarken karıştırıcı döner → ağır el/kol yaralanması	3	3	3	**27**	**1 · Kritik**
R-02 Meraklı içeriden kişi → G02 paylaşılan servis hesabı → sıcaklık/satış eşiğini değiştirir (SF-02) → uygunsuz sıcaklıkta süt satılır → tüketicide ciddi hastalık	2	3	1	**6**	**2 · Orta · S=3**
R-03 Tedarik zinciri → G04 değiştirilmiş servis paketi, G03 USB'den yüklenir → yıkama bitmeden "tamamlandı" bilgisi üretilir (SF-04) → kirli hattan satış → tüketicide ciddi hastalık	1	3	1	**3**	**3 · Düşük · S=3**
R-04 Hedefli saldırgan → G04 bakım projesi değiştirilir, G05'ten yerelde yüklenir → yeniden başlama engeli kalkar (SF-03) → enerji dönüşünde karıştırıcı kendiliğinden başlar → ağır yaralanma	1	3	1	**3**	**4 · Düşük · S=3**

Kritik 18–27 | Yüksek 9–17 | Orta 4–8 | Düşük 1–3

Puan gerekçeleri. R-01: varsayılan parola ve geniş yazma yetkisi (L3), karıştırıcıya kaptırma ile ağır yaralanma (S3), sürekli açık uzak yol (E3). R-02: paylaşılan servis şifresi gerekir (L2), koşullu ciddi biyolojik zarar (S3), yalnız makine başından (E1). R-03: paket değiştirme + fiziksel yükleme zinciri (L1), hijyen yetersizliğinin ürüne geçmesi (S3), son adım USB (E1). R-04: makineye özel proje bilgisi gerekir (L1), R-01 ile aynı yaralanma (S3), yerel bakım bağlantısı (E1).

Önlemler ve hedef puanlar

ID	Önerilen önlem	Sorumlu (A / R)	Hedef tarih	Hedef L/S/E
R-01	Uzak yazmayı kapat, LAB2 Görev B; H01/H03/H06	İşletmeci / OT-servis	06.12.2026	1/3/2 = 6
R-02	Servis rollerini ayır, eşik değişikliğine onay; H02	İşletmeci / gıda sorumlusu	04.02.2027	1/3/1 = 3
R-03	Yıkama–satış kilidi, imzalı paket; H04/H05	İşletmeci / servis + gıda	04.02.2027	1/3/1 = 3

ID	Önerilen önlem	Sorumlu (A / R)	Hedef tarih	Hedef L/S/E
R-04	Bağımsız yeniden başlama engeli, proje bütünlüğü; H03/H05	İşletmeci / servis + emniyet	04.02.2027	1/3/1 = 3

Tarihler ders notundaki 30/90 gün önerisinden hesaplandı; ölçülmüş artık risk değildir. **S=3 hiçbir önlemle otomatik olarak S=1'e düşürülmez**; düşen L ve E'dir, fiziksel zincirin kesildiği testle (KT01–KT07) ayrıca gösterilir.

1 **En yüksek öncelikli senaryonuz hangisi? Bir cümleyle: neden bu?**

R-01: Ders kabulündeki (V05/V06/V08) internetten, varsayılan parolayla ulaşılabilen ve sürekli açık servis yolu, tek adımda kapak korumasını kapatıp bakımcıyı ağır yaralanmaya açık bırakabiliyor.

2 **S=3 olup skoru düşük kalan senaryonuz var mı? Nasıl görünür kılacaksınız?**

Evet: **R-02 (6), R-03 (3), R-04 (3)**. Register'da ayrı bir **"S=3 izleme listesi"** sütunu tutulur: sahibi, hedef tarihi ve kapanış testi yazılır. Skor sıralamasından bağımsız olarak her gözden geçirmede ilk bakılan satırlardır. Önlem uygulanıp test kanıtı ya da yetkili yazılı kabul olmadan kapatılmaz.

> **Altın kural:** Zincir "veri çalındı" ile bitiyorsa emniyet bulgusu değildir — bir adım daha gidin: bu, hattaki insana ne yapar? Bu Register'daki dört zincirin hepsi bir insanda bitiyor: bakımcı ya da sütü içen kişi.

Ders notu tartışma soruları

3 **Aynı kapıyı iki farklı profil kullanırsa skor değişir mi?** DERS NOTU

Profil adı değişti diye değişmez. Gereken beceri, erişim koşulu ya da etkilenen işlev değişiyorsa L veya E değişir ve bu ayrı gerekçeyle **ayrı bir satır** olarak yazılır.

4 **Skoru 27 ama S=1 olan mı, skoru 3 ama S=3 olan mı önce?** DERS NOTU

S=1 iken en yüksek skor 3 × 1 × 3 = **9** olur; 27/S=1 bu ölçekte mümkün değildir. Geçerli karşılaştırma 9/S=1 ile 3/S=3 arasındadır: üretim kaybı önemlidir ama **insana zarar veren S=3 gözden kaçırılmaz**, ayrı listede izlenir.

5 **Emniyete dokunmayan siber senaryo Register'a girmeli mi?** DERS NOTU

Girer, ama S=1 ile ve "emniyet bulgusu" diye sunulmadan. Örneğin satış geçmişinin değiştirilmesi bir ticari ve veri riskidir. Bir fiziksel zarar zinciri bulunursa ayrıca yazılır.

6 **Tedarikçinin "güvenli" beyanına ne kadar güvenirsiniz; hangi kanıt gerekir?** DERS NOTU

Beyan tek başına yetmez. Kurulu sürüm listesi, devre ve ağ şeması, yazma yetkilerinin dökümü ve ilgili test kayıtları gerekir. Bu ödevde firmadan belge istenmedi; eksik bilgi açık bırakıldı.

7 **Register ne zaman yeniden puanlanır?** DERS NOTU

Yeni bir açık yayımlandığında, yazılım veya ağ değiştiğinde, bakımdan sonra, bir olay yaşandığında ya da bir varsayım (V-kodu) yanlış çıktığında. Bunlar dışında planlı gözden geçirmede.

Ek sorularımız

8 **Otomatta internet bağlantısı hiç yoksa Register nasıl değişir?** EK SORU

R-01'in uzak yolu (G01) temel kurulumdan çıkar ve en kritik satır düşer. Ancak yerel ekran, USB ve bakım yolu kalır: R-02, R-03 ve R-04 geçerliliğini korur. "İnternet yok" demek "risk yok" demek değildir.

9 **Önlemden sonra skor düşmüyorsa önlem işe yaramamış mı olur?** EK SORU

Hayır. R-03 ve R-04 zaten L1/E1'de, ölçeğin tabanından aşağısı yok; R-02'de yalnız L 2'den 1'e iner. Önlemin değeri skorda değil, **zincirin kesildiğini gösteren testte** görünür (ör. KT04: yıkama sürerken satış talebi reddedildi). Kalan

belirsizlik ayrıca kaydedilir.

10 **Bu Register'da en çok tartışılabilecek puan hangisi?** EK SORU

R-02 ve R-03'ün **S=3** puanı. Sütün ne kadar süre, hangi sıcaklıkta kaldığı ve bulaşma koşulları bilinmiyor; ciddi biyolojik sonuç koşullu bir kabul. Gıda sorumlusu incelemesi S=2'ye indirebilir ya da S=3'te bırakabilir. Gerekçe her durumda yazılmalıdır.

11 **Yıkama yöntemi bilinmiyorsa R-03 nasıl yazılmalı?** EK SORU

Kimyasal, sıcak su ya da özel sensör uydurulmaz. R-03 yalnız "otomatik yıkamanın tamamlandı bilgisi satış iznini etkiliyor" kabulüne (V09) dayanır. Yıkamanın yeterli olup olmadığı hakkında saha sonucu vermez; V09 yanlış çıkarsa senaryo yeniden yazılır.

Varsayımlar

V01–V09 kullanıldı (Makine profili). Puanlar eğitim modeline aittir; gerçek makinede tespit edilmiş açık veya olay değildir.

Bu föyün çıktısı **Risk Register** → Evidence Pack **EP 04 Risk Assessment** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 4 · ARMINOKS SÜT OTOMATI

Secure Remote Access

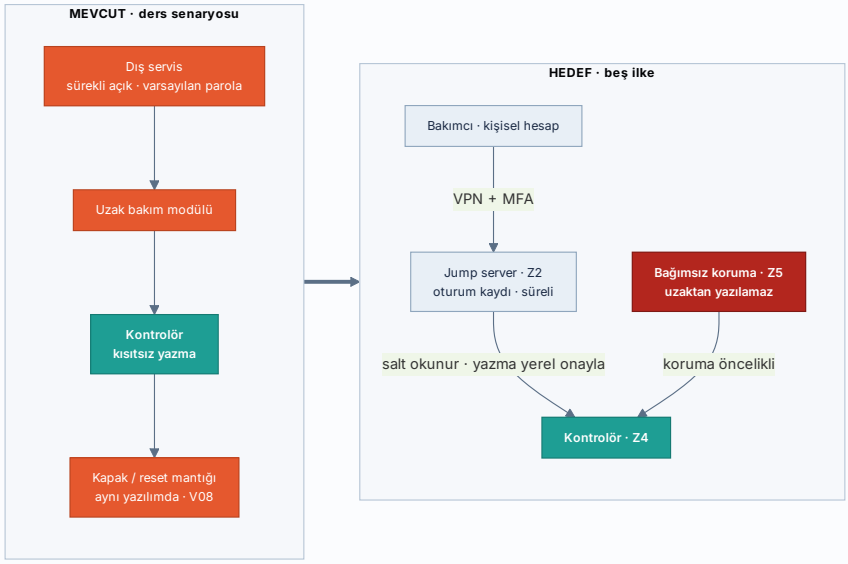
Çıktı: Secure Architecture

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Kavram: İki katman, ikisi de şart: **erişim güvenliği** (girişi zorlaştır: ara nokta, VPN, MFA, kişisel hesap, kayıt, varsayılan kapalı) + **emniyet bağımsızlığı** (girse bile insan korunur).

Arminoks bağlamı: "Mevcut" taraf ders senaryosudur (V05/V06/V08): sürekli açık uzak servis, varsayılan parola, kontrolöre kısıtsız yazma. Üreticinin gerçek kurulumunda bunların bulunduğu **söylenmez**. "Hedef" taraf, LAB2 Görev B'deki altı kararın ve LAB1'deki ayrı safety yolunun birleşimidir.

Görev A — mevcut → hedef



Mevcut: Dış servis, sürekli açık yoldan ve varsayılan parolayla bakım modülüne, oradan kontrolöre yazabiliyor. Kapak ve yeniden başlama koşulları aynı yazılımda olduğu için **tek bir oturum koruma mantığını değiştirebilir**. Kişisel hesap, oturum kaydı ve değişiklik onayı yok.

İlke	Hedefte otomata uygulanışı	Kabul ölçütü
1 · Ara nokta	Yalnız Z2 jump server üzerinden bakım	C01/C02 dışındaki yollar reddedilir
2 · VPN	Bakım trafiği yalnız tanımlı tünelden	Tünel dışı bağlantı yok; VPN yetki vermez
3 · MFA + kişisel hesap	Operatör, servis, yetkili değişiklik rolleri ayrı	Paylaşılan U02 kalkar; her işlem bir kişiye bağlı
4 · Kayıt	Oturum, dosya/ayar değişikliği, onay birlikte	Değişen sürüm ve sorumlu izlenebilir
5 · Varsayılan kapalı	İş emri + yerel onay + bakım penceresi	Süre bitince oturum ve yetki kapanır

Tablo kurulmuş ürün listesi değil, hedef tasarım gereksinimidir. Cihaz bunları desteklemiyorsa harici bir geçit veya farklı servis yöntemi seçilir.

Görev B — functional safety köprüsü

1 **Saldırgan tüm önlemlere rağmen içeri girerse: emniyet fonksiyonu etkilenir mi? Neden?**

Mevcut yapıda (ders kabulü) evet. Kapak ve yeniden başlama mantığı normal kontrol yazılımında (V08); kontrolöre yazabilen herkes SF-01/SF-03'ü kapatabilir. **Hedefte hayır olmalı:** C01–C03 aşılsa bile koruma mantığı, ayarları ve çıkışları ayrı (Z5) olduğu ve uzaktan yazılamadığı için karıştırıcı kapak açıkken dönemez. Aynı şey satış için de geçerli: normal satış komutu SF-02/SF-04 kilitlerini aşamaz. Bu bir hedeftir, doğrulanmış durum değildir.

2 **Emniyet fonksiyonunun kontrol sisteminden bağımsız çalışması için GEREKSİNİMİ yazın (çözümü değil).**

ID	Gereksinim	Doğrulama
H01	Kapak açık veya koruma durumu geçersizken, normal kontrolör ya da uzak komut karıştırıcıda tehlikeli hareket **oluşturamamalıdır**	KT01
H02	Sıcaklık ölçümü geçersiz veya ürün uygunluğu belirsizken panel, ödeme ya da uzak komut satışı **açamamalıdır**	KT02
H03	Enerji, haberleşme veya reset dönüşü kendiliğinden tehlikeli hareket **başlatmamalıdır**	KT03
H04	Satış ile yıkama birbirini dışlamalı; yıkama tamamlandığı doğrulanmadan satışa geçilememelidir	KT04
H05	Koruma ayarları yalnız yetkili yerel süreçle değişebilmeli; paket kaynağı, bütünlüğü ve önceki sürüm korunmalıdır	KT05
H06	Uzak erişim kişisel kimlik ve yerel onaylı süreyle sınırlı olmalı, koruma programlama yoluna **yazma vermemelidir**	KT06
H07	Ağ veya servis kaybı koruma davranışını bozmamalı; satış kilidi sürerken güvenli soğutma devam etmelidir	KT07

> **Tarafsızlık notu:** Bu föy çözüm tasarlatmaz; gereksinimi tanımlatır. Tasarım kararı firmanızındır. Gereksinimler marka seçmez; Safety PLC, safety rölesi ya da başka bir çözümle karşılanabilir.

Doğrulama planı (KT01–KT07)

Test	Gereksinim	Kontrol ve beklenen sonuç
KT01	H01 / SF-01	Kapak açık/hatalıyken hareket komutu → hareket olmaz; duruş-erişim süresi ölçülür
KT02	H02 / SF-02	Geçersiz sıcaklık ve ürün durumu → satış kapalı, uyarı var, soğutma sürer
KT03	H03 / SF-03	Reset, enerji ve haberleşme dönüşü → ayrı yerel başlatma olmadan hareket yok
KT04	H04 / SF-04	Yıkama sürerken veya durum belirsizken satış talebi → reddedilir
KT05	H05	Bozuk/yanlış paket veya yetkisiz ayar → reddedilir, kayıt ve geri dönüş yolu var
KT06	H06	Yanlış rol, eksik MFA, süre sonu → giriş/yazma reddedilir, geçici erişim kapanır
KT07	H07	Ağ/panel kaybı → koruma sürer, satış kendiliğinden açılmaz, soğutma güvenli

Testler gerçek makinede yapılmadı; yetkili bir düzenekte, kimseyi tehlikeye sokmadan uygulanmaları önerilir.

Süreli bakım prosedürü (EP 06)

1. İşletmeci iş emrini onaylar: amaç, kişi, süre; satış durumu belirlenir.
2. Mevcut proje, ayar ve kayıtlar yedeklenir; sürüm ve özet değeri (hash) yazılır.
3. Yerel sorumlu C01/C02'yi süreli açar; bakımcı VPN + MFA + kişisel hesapla girer.
4. Önce salt okunur tanılama. Yazma ayrı onay ve güvenli bakım koşuluyla açılır; Z5 hiçbir zaman uzak oturuma açılmaz.
5. Değişiklikten sonra ilgili KT testleri ve ürün uygunluğu kontrolleri yapılır.
6. Süre bitince erişim kapanır; oturum, dosya ve test kayıtları iş emrine bağlanır. Satış yalnız yerel onayla açılır.

Ek sorularımız

3 **Bakımcı ekranı görebiliyorsa program da yükleyebilmeli mi?** EK SORU

Hayır. Görme yetkisi yazma yetkisi değildir. Uzak tanılama (ekran, alarm, sıcaklık geçmişi) ile kontrolör ve koruma ayarı değiştirme **ayrı roller** olarak yetkilendirilir. Araç bu ayrımı desteklemiyorsa uzak oturuma genel yönetici yetkisi verilmez.

4 **Bakım sırasında bağlantı koparsa ne olur?** EK SORU

Geçici yetki kendiliğinden kapanır; koruma yerelde çalışmayı sürdürür. Yarım kalmış bir değişiklik varsa satış ve tehlikeli hareket açılmaz; bilinen iyi sürüm ve test sonucu olmadan uzaktan yeniden başlatma yapılmaz. Soğutma H07'ye göre sürer.

5 **Ayrı bir Safety PLC varsa tamamen güvende miyiz?** EK SORU

Hayır. Ortak bakım hesabı veya ortak programlama aracı iki sistemi birden değiştirebilir. Sensör ve çıkış paylaşımı, ortak güç kaynağı ve konfigürasyon yetkileri de incelenir. Bağımsızlık bir cihaz alımı değil, **değiştirme yetkisinin** ayrılmasıdır (H05/H06).

6 **Öncelikli risk zinciri (R-01) nerede kırılır?** EK SORU

Üç yerde: **C01**'de süreli ve kimlikli giriş (girişi zorlaştırır), **C03**'te salt okunur varsayılan (yazmayı zorlaştırır), son halkada **H01/H03** bağımsız koruma (girse bile karıştırıcı dönmez). İlk iki katman olasılığı (L, E) düşürür; son katman insanı korur. Kanıtı diyagram değil, KT01/KT03/KT06 testleridir.

Varsayımlar

V05, V06 ve V08 kullanıldı (Makine profili). Otomatın gerçekte uzak erişime sahip olup olmadığı ve kontrolörün rol ayrımını destekleyip desteklemediği doğrulanmalıdır.

Bu föyün çıktısı **Secure Architecture** → Evidence Pack **EP 02 Network Architecture + EP 06 Remote Access Procedure** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 5 · ARMINOKS SÜT OTOMATI

SBOM / CVE / Patch

Çıktı: Vulnerability Decision

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

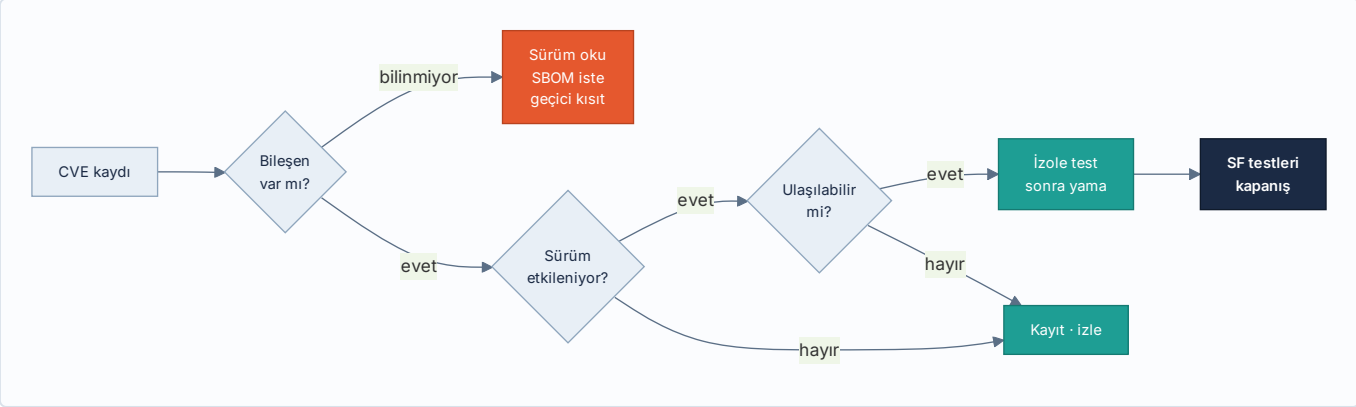
Kavram: SBOM = yazılım malzeme listesi · **CVE** = açığın kayıt no'su · **CVSS** = ciddiyet (0–10). Bir CVE sizi etkiler mi? Üç şart: **bileşen var, sürüm etkileniyor, açık ulaşılabilir**.

Arminoks bağlamı: Föyün verdiği kayıt temsilidir (V10) ve aşağıda föydeki gibi kullanıldı. Ayrıca otomatın panel yazılımı için gerçek CVE adayları ayrı bir araştırmada incelendi (sayfa sonundaki kutu). Kurulu sürümler okunamadığı için **iki durumda da karar "etkilenme belirsiz, inceleme gerekli"** çıkıyor.

Verilen zafiyet kaydı

Bileşen	Sürüm	CVE	Önem	Yama
Component X (PLC firmware kütüphanesi)	2.4	CVE-XXXX-XXXX	Critical (CVSS 9.8)	Mevcut

Görev — karar akışı



1 Bu CVE sizi gerçekten etkiliyor mu? (üç şartı kontrol edin)

Şart	Bilinen	Gereken bilgi
Bileşen var mı?	Gerçek bileşen listesi yok	Kontrolör modeli ve üreticiden SBOM
Sürüm etkileniyor mu?	2.4 yalnız föy girdisi	Kurulu sürüm (sahada okunur) + resmî duyuru
Açık ulaşılabilir mi?	Protokol ve erişim yolu bilinmiyor	Açığın kullandığı servis LAB2'deki bir conduit'ten geçiyor mu?

Karar (VD-01): etkilenme belirsiz. Bilinmeyen bilgi "etkilenmiyoruz" sonucuna çevrilmez. CVSS 9.8, açığın genel ciddiyetidir; bu otomattaki riski tek başına belirlemez.

2 Üretimi hemen durdurur musunuz? Neden / neden değil?

Yalnız CVSS puanı yüzünden **otomatın tüm enerjisi kesilmez**; aksi hâlde soğutma da durur ve tanktaki süt bozulur. Bunun yerine: uzak erişim kapatılır (C01), USB yüklemesi askıya alınır (C04), koruma ve ürün uygunluğu kontrol edilir. Koruma bütünlüğünden şüphe varsa satış ve tehlikeli hareket güvenli duruma alınır, soğutma sürer. Devam kararını yetkili işletmeci verir.

3 Yamayı doğrudan mı uygularsınız, önce test mi? Nerede test?

Önce test. Yamanın doğru ürün ve sürüme ait resmî paket olduğu (kaynak, imza/hash) doğrulanır; mevcut proje ve ayarlar yedeklenir. Test, aynı kontrolör ve panel sürümüyle kurulmuş **izole bir düzenekte** yapılır: dolum, yıkama, sıcaklık alarmı ve koruma davranışı denenir. Düzenek yoksa yama planlı bir bakım penceresinde, satış kapalı ve geri dönüş planı hazırken uygulanır; canlı satış sırasında asla.

4 Bu yama bir safety validation etkiliyor mu? Nasıl anlarsınız?

Sürüm notu ve değişen bileşenin **SF-01–SF-04 ile ilişkisi** incelenir. Kapak/reset mantığı, zamanlama, sıcaklık ölçümü, yıkama sırası ya da çıkış davranışı değişiyorsa ilgili doğrulama tekrarlanır (KT01–KT04). "Dolum çalışıyor" demek yeterli değildir; korumanın hâlâ devreye girdiği test edilmelidir.

5 Yama mümkün değilse compensating control (telafi edici önlem) ne olur?

- Gereksiz servisler ve uzak yazma kapatılır; erişim LAB2 Görev B kararlarına çekilir.
- Servis hesabı kişiselleştirilir, USB'den yükleme engellenir.
- Açığın ulaşılabildiği conduit (ör. C01) tamamen kapatılır veya izlenir.
- Önlemin bu açığa yettiği test edilir, süreli izleme kararı yazılır.
- Kalan fiziksel risk kabul edilemiyorsa satış ve ilgili hareket kapalı tutulur.

Kayıtlar (EP 09 · 10 · 11)

Kayıt	İçerik	Durum
EP 09 SBOM taslağı	W01 panel uygulaması · W02 kontrol programı · W03 bakım aracı · W04 koruma konfigürasyonu · A08 uzak geçit yazılımı · Component X 2.4 (temsili)	Sürümler bilinmiyor; gerçek SBOM değil
EP 10 VD-01	06.11.2026 · Component X 2.4 · temsili CVE · CVSS 9.8 · etkilenme belirsiz · geçici kısıt: C01/C04 kapalı	Açık
EP 11 Yama kaydı	Öncesi (sürüm, yedek, onay) → paket (kaynak, hash) → test (düzenek, KT sonuçları) → kurulum (iş emri) → geri dönüş → kapanış	Plan var; uygulanmadı

Bilinmeyen alanlara örnek değer yazılmadı. Tam SBOM için tedarikçi, kurulu sürüm, bağımlılıklar ve lisans bilgileri gerekir.

> **Gerçek kayıtlarla ek inceleme (06.11.2026):** Panelin LS eXP20 ailesinden olabileceği görsel olarak saptandı. Bu aileye ait yazılımlar için gerçek CVE adayları, etkilenen sürüm aralıkları ve kanıtları yazılım/CVE envanterinde ve teknik raporda yer alıyor. Kurulu sürüm okunmadığı için bunlar **koşullu adaydır**; üç şartın ilk ikisi doğrulanmadan etkilenme iddia edilmez.

Ek sorularımız

6 Raporlardaki gerçek CVE adayları bu föyün kararını değiştirir mi? EK SORU

Karar mantığını değiştirmez, girdisini değiştirir. Temsili kayıtta da gerçek adaylarda da ilk eksik aynıdır: **kurulu sürüm**. Sahada panel ve kontrolör sürümü okunduğunda her aday için üç şart yeniden işletilir; etkilenen çıkarsa VD-02 kaydı açılır. İlgisiz bir CVE'yi makineye aitmiş gibi eklemek doğru olmaz.

7 Hash değeri doğruysa paket güvenilir midir? EK SORU

Ancak hash **güvenilir bir kaynaktaki** referansla karşılaştırıldıysa. Paketle aynı yerden indirilen hash, değiştirilmiş paketi de "doğru" gösterebilir. Üretici imzası, doğru ürün/sürüm uyumu ve indirildiği kanal da kontrol edilir (H05).

8 Kontrolör eski sürüme geri dönüşü desteklemiyorsa ne yapılır? EK SORU

Geri dönüş yoksa canlı otomatta deneme yapılmaz. Önce yedek cihaz, üretici destekli kurtarma veya tam proje yedeğinden geri yükleme yolu hazırlanır. Bu sağlanamıyorsa yama ertelenir; telafi önlemleri (soru 5) sürer ve karar kayda geçer.

9 **Bir zafiyet kaydı hangi kanıtla kapatılır?** EK SORU

Dört kanıt birlikte: etkilenen varlık ve sürüm belli; yama veya telafi önlemi uygulandı; ilgili SF testleri (KT01–KT04) geçti ve yeni sürüm kaydedildi; sorumlu kişi kapanışı imzaladı. Bunlardan biri eksikse kayıt "açık" kalır.

Varsayımlar

V01, V05, V08 ve V10 kullanıldı (Makine profili). Kontrolör ve panel sürümleri sahada okunmalı, üreticiden SBOM istenmelidir.

Bu föyün çıktısı **Vulnerability Decision** → Evidence Pack **EP 09 · 10 · 11** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 6 · ARMINOKS SÜT OTOMATI

CRA Incident Simulation

Çıktı: Incident Workflow

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Senaryo: Saat 10:15. Servis hesabında yetkisiz erişim tespit edildi. PLC konfigürasyonu değişmiş olabilir. Makine hâlâ çalışıyor. Vardiya sorumlusu sizsiniz.

Kavram: Bir olayda en değerli iki şey **zaman ve kanıttır**. CRA'nın 24s / 72s / 14 gün yükümlülükleri, iyi bir müdahale akışının doğal kilometre taşlarıdır — ezber değil.

Arminoks bağlamı: "Makine hâlâ çalışıyor" bu otomatta şu anlama gelir: tank soğutuluyor, karıştırıcı programına göre dönüyor, müşteri gelirse dolum yapılıyor. Değişmiş olabilecek konfigürasyon sıcaklık eşiğini (SF-02), yıkama sırasını (SF-04) ya da kapak/reset mantığını (SF-01/SF-03) etkileyebilir. Servis hesabı ve kontrolör ders kabulüdür (V01, V07); olay masa başı bir eğitim senaryosudur, yaşanmış bir olay değildir.

Görev — zaman çizgisini doldurun



1 10:15 — ilk 15 dk: Kimi ararsınız? İlk üç eyleminiz?

Ararım: işletmenin bakım/OT sorumlusu, gıda güvenliği sorumlusu ve olay yöneticisi (önerilen roller; Arminoks çalışanı değil).

1. **İnsanı ve ürünü koru:** Satış ve dolumu tanımlı prosedürle askıya al, bakım alanına girişi engelle. Soğutmayı **kesme**; enerjiyi tamamen kesmek sütü bozar ve kanıtı (RAM'deki durum) siler.
2. **Erişimi kes, kanıtı bozmadan:** Şüpheli servis oturumunu sonlandır, hesabı askıya al, uzak erişim yolunu (C01) kapat. Reset, fabrika ayarı ve program yükleme **yapılmaz**.
3. **Yaz:** Tespit saati, kimin neyi gördüğü, panel durumu, bağımsız bir termometreyle tank sıcaklığı ve alınan kararlar. Saat kaynağı ve sapması not edilir.

2 İlk 2 saat: Emniyet güvende mi? Neyi korursunuz (kanıt!)? Hangi hesap kapatılır?

Emniyet güvende mi? Henüz söylenemez. Satış kapalı kalır; yetkili ekip kapak koruması, sıcaklık ölçümünün doğruluğu ve yıkama–satış ayrımını kontrol eder. 10:15'ten önceki satışlar gıda sorumlusunca ayrıca değerlendirilir; sıcaklık geçmişi bilinmiyorsa "güvenli" sayılmaz.

Korunacak kanıt	Nasıl
Servis hesabı ve oturum kayıtları	Yetkili erişimle dışa alınır, silinmez
Kontrolör konfigürasyonu ve proje	Salt okunur kopya; bilinen iyi yedekle karşılaştırılır
Sıcaklık, alarm ve yıkama geçmişi	Tutuluyorsa korunur; yoksa "yok" diye yazılır, uydurulmaz
USB satış geçmişi	Orijinal korunur, kopya üzerinde çalışılır
Kanıt teslim kaydı	Kim, neyi, ne zaman, hangi yöntemle aldı; SHA-256 ve saklama yeri

Kapatılan hesap: ihlalle ilişkili **servis hesabı** (askıya alınır, silinmez). Paylaşılan bir hesapsa aynı parolayı bilen herkes etkilenir; parola değişir ve kapsam yazılır. Diğer hesaplar körlemesine silinmez.

3 24 saat — CRA erken uyarı: Hangi bilgi hazır olmalı?

- Olay kimliği; tespit ve farkına varma saatleri
- Ürün: Arminoks süt otomatı, bilinen model bilgisi (sürüm tahmin edilmez)
- Ne görüldü: servis hesabında yetkisiz erişim; olası konfigürasyon değişikliği
- Etki: insan, ürün (satışlar) ve işletme etkisi; alınan önlem (satış kapalı, erişim kesik)
- **Aktif istismar** şüphesi var mı; başka otomatları etkileyebilir mi
- Bilinmeyenler ve iletişim sorumlusu

CRA bildirimi **üreticinin** yükümlülüğüdür (ENISA ve yetkili CSIRT'e). Vardiya sorumlusu kendisi resmî bildirim göndermez; bilgiyi üreticiye ve işletme yönetimine hazırlar.

4 72 saat — CRA bildirim: Kök neden, etki, önlem — kim ne yapıyor?

Rol	72 saate kadar yaptığı
Olay yöneticisi	Tek zaman çizgisi, kararlar ve görev dağılımı
Bakım/OT sorumlusu	Erişim yolu, konfigürasyon farkı, gerçek yazılım sürümleri; geçici kısıtları sürdürür
Gıda güvenliği sorumlusu	Etkilenen satış aralığı, sıcaklık/yıkama kayıtları, ürün kararı (geri çağırma gerekir mi)
Üretici / bildirim sorumlusu	Ürün kapsamı, kök neden analizi, düzeltme; CRA bildirimini yürütür

Kök neden henüz bulunmadıysa "inceleme sürüyor" yazılır; **72 saatlik bildirim kesin kök neden beklenerek geciktirilmez**. Hesap kapatıldı diye otomat yeniden satışa açılmaz.

5 14 gün — son rapor: Hangi loglar/kayıtlar korunmuş olmalı?

İlk uyarı; oturum ve hesap kayıtları; konfigürasyonun **önce/sonra** kopyaları ve hash'leri; kanıt teslim zinciri; sıcaklık, satış ve yıkama geçmişi; ürün kararları; değişiklik onayları; KT testlerinin sonuçları; geri dönüş planı ve yeniden işletme izni.

CRA süre ayrımı (Madde 14): Aktif istismar edilen bir **zafiyette** son rapor, düzeltici veya hafifletici önlem hazır olduktan sonra en geç **14 gün**; ciddi bir **olayda** ise 72 saatlik bildirimden sonra **1 ay** içinde verilir. Bildirim yükümlülükleri 11.09.2026'dan itibaren uygulanır. Hangisinin geçerli olduğu ürün kapsamı doğrulanınca belirlenir.

> **En sık hata:** "Resetleyip devam edelim" — o düğme, kanıtı sonsuza dek siler. Önce emniyet, hemen sonra kanıt. Bu otomatta ek bir tuzak daha var: "her şeyi kapatalım" — soğutma da kapanır, süt bozulur.

Ek sorularımız

6 Soğutma sürerken kanıt nasıl korunur? EK SORU

Otomat kapatılmadan **salt okunur** yöntemle konfigürasyon ve kayıtlar alınır; yazma yapan hiçbir araç kurulmaz. Ekran fotoğraflanır, bağımsız termometreyle sıcaklık ölçülüp saatle yazılır. Kanıt almak için enerji kesmek gerekiyorsa önce sütün nasıl korunacağı (başka tanka aktarma veya imha kararı) gıda sorumlusuyla belirlenir.

7 USB satış geçmişi kanıt olarak ne kadar güvenilirdir? EK SORU

Sınırlıdır. Kayıt değiştirilmiş kontrolör tarafından yazıldıysa saldırgan onu da değiştirmiş olabilir. Değeri, **bağımsız kaynaklarla** (ödeme sistemi, kasa kayıtları, müşteri şikâyetleri) tutarlı olup olmadığına bakılarak ölçülür. Orijinal dosya hash'lenip saklanır, analiz kopya üzerinde yapılır.

8 Şüpheli bakım bilgisayarı ve USB belleklerle ne yapılır? EK SORU

Ağdan ayrılır ama kapatılmaz; kullanımı durdurulur ve kanıt olarak etiketlenir. Son 30 gün içinde otomata takılan USB bellekler toplanır. Temiz olduğu doğrulanmadan hiçbiri yeniden kullanılmaz; geri yükleme için **olaydan önceki, hash'i bilinen** yedek kullanılır.

9 **Otomat yeniden satışa ne zaman açılır?** EK SORU

Dört koşul birlikte sağlanınca: (1) konfigürasyon bilinen iyi sürüme döndü ve hash'i doğrulandı; (2) KT01–KT04 koruma testleri geçti; (3) tank temizlendi, sıcaklık bağımsız ölçümle doğrulandı ve gıda sorumlusu ürünü onayladı; (4) erişim yolu LAB2 Görev B'ye göre kapatıldı. Onay yazılı ve kayıtlı verilir.

Varsayımlar

V01, V05 ve V07 kullanıldı (Makine profili). Kaynaklar: CRA — Regulation (EU) 2024/2847 Madde 14 ve 71; Avrupa Komisyonu — CRA raporlama (erişim 06.11.2026). Gerçek olay olmadığından doldurulmuş log, olay numarası veya test sonucu sunulmadı.

Bu föyün çıktısı **Incident Workflow** → Evidence Pack **EP 13 Incident Response** başlığına oturur. Durum: **Taslak**.

LABORATUVAR 7 · ARMINOKS SÜT OTOMATI

AI Safety Challenge

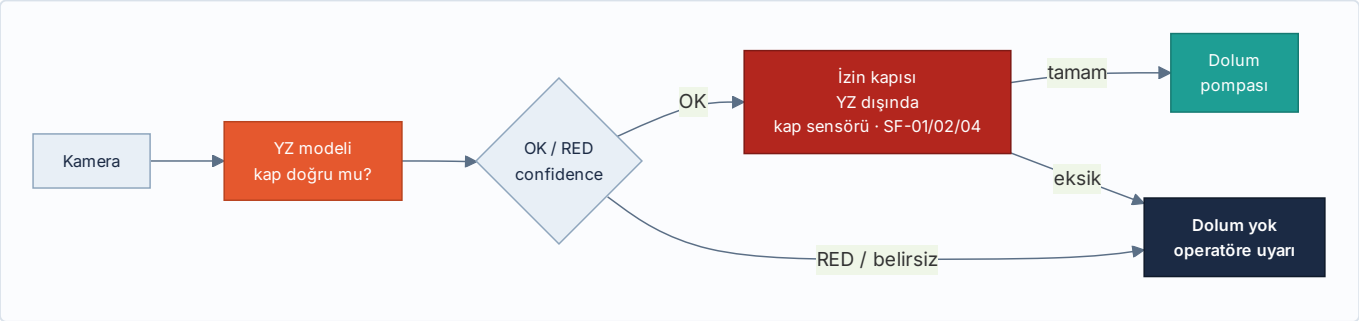
Çıktı: AI Fail-Safe Decision

Ad Soyad	Öğrenci No	Grup	Tarih
Batuhan Yaşar Özkan	230541050	Gündüz-B	06.11.2026

Kavram — Prediction ≠ Safety: Yapay zekâ bir karar üretir; güvenliği garanti eden mimari **YZ'nin dışında** tanımlanmalıdır. Araçlar: **fail-safe · human override · monitoring · confidence threshold · fallback**.

Arminoks bağlamı: Otomatta kamera, robot veya yapay zekâ olduğuna dair kanıt yok. Föyün zinciri (Kamera → YZ Modeli → OK / RED → Parametre → Robot) bu makineye **önerilen bir eğitim işlevi** olarak uyarlandı: kamera dolum ağzının altındaki kabı görür, model "kap doğru ve yerinde" derse doluma izin önerir. Robotun yerini **dolum pompası** alır. Föydeki "kusurlu parça" bu makinede **uygunsuz kap**tır (yanlış boyut, devrik, kirli veya hiç yok).

Görev — üç başarısızlıkta güvenli davranış



Kırmızı **izin kapısı** YZ'nin dışındadır: model OK dese bile bağımsız kap sensörü, sıcaklık (SF-02), yıkama (SF-04) ve kapak (SF-01) koşulları sağlanmadan pompa çalışmaz. Föydeki zincir uyarlandı UYARLANDI.

1 Model yanlış sınıflandırdı: Kusurlu parçaya OK verdi. Sistem ne yapmalı? İkinci kontrol / insan onayı var mı?

Bu makinede: model **uygunsuz kaba** (devrik, yanlış boyut, kap yok) OK verdi.

- **İkinci kontrol olmalı (önerilen):** YZ'nin OK'u tek başına pompayı çalıştıramaz. İzin kapısına bağımsız bir kap/konum sensörü (ağırlık veya yakınlık) eklenmesi önerilir; broşürde böyle bir sensör yoktur. Sensör "kap yok" diyorsa dolum başlamaz. İki karar çelişirse **dolum yok** (fail-safe).
- **İnsan onayı:** Çelişkide operatör uyarılır; operatör kabı düzeltebilir ama sıcaklık, yıkama ve kapak kilitlerini **aşamaz**.
- **Kayıt:** Görüntü zamanı, model sürümü, YZ kararı ve sensör kararı saklanır; tekrarlayan yanlış OK'lar model gözden geçirmesini tetikler.

2 Girdi manipüle edildi: Kamera verisi bozuk/sahte. Nasıl fark edilir? Şüpheli girdide ne yapılır?

Nasıl fark edilir (monitoring): görüntünün zaman damgası eski veya sırası bozuk; akış donmuş ya da aynı kare tekrarlanıyor; görüntü kalitesi, ışık veya bulanıklık aniden değişti; kameranın gördüğü ile kap sensörü arasında tutarsızlık var. Bu işaretler sahteciliği **kesin** kanıtlamaz; gerçek algılama başarımı test edilmelidir.

Ne yapılır: Şüpheli girdide YZ kararı **kabul edilmez**, otomatik dolum bekletilir, operatöre ve bakım sorumlusuna olay bildirilir, görüntüler kanıt olarak saklanır. Kameranın arızası koruma işlevini devre dışı bırakamaz; soğutma sürer.

3 Confidence düştü: Model "emin değilim" diyor. Eşik ne olmalı? Altında: dur / insana sor / fallback?

Eşik ne olmalı? Gerçek kamera ve doğrulama verisi olmadan 0,90 ya da 0,95 gibi bir sayı **uydurulmaz**. Eşik; boş, devrik, yanlış boyutlu ve doğru kap örnekleri, farklı ışık koşulları ve bozuk görüntülerle kurulmuş bağımsız bir veri

setinde, "yanlış OK oranı neredeyse sıfır" kabul ölçütüyle belirlenir. Confidence, emniyet güvenilirliği değildir; model veya kamera değişince eşik yeniden doğrulanır.

Altında ne olur? Sırasıyla: **dur** (dolum yok) → **insana sor** (operatör kabı görüp onaylar; temel kilitler yine geçerli) → **fallback** (YZ'siz, yalnız kap sensörüyle çalışan doğrulanmış manuel mod). Eşik doğrulanana kadar YZ'li otomatik dolum hiç devreye alınmaz.

Karar tablosu — AI Fail-Safe Decision

Başarısızlık	Tanımladığınız güvenli davranış (hangi kavramla?)
Model yanlış sınıflandırdı	YZ'nin OK'u tek başına yetmez; bağımsız kap sensörü onaylamazsa dolum yok, operatör uyarılır — **fail-safe + human override** (insan temel kilitleri aşamaz)
Girdi manipüle edildi	Eski, donmuş, tekrarlı veya sensörle çelişen görüntüde YZ kararı reddedilir, dolum bekler, olay kaydedilir — **monitoring + fail-safe**
Confidence düştü	Doğrulanmış eşiğin altında karar "belirsiz": dolum yok → operatör onayı → YZ'siz manuel mod — **confidence threshold + fallback**

Ek sorularımız

4 YZ kabı doğru buluyorsa süt de satılabilir mi? EK SORU

Hayır. Model yalnız **kabı** görür. Sütün sıcaklığı, tankın temizliği ve yıkamanın tamamlanması kameranın göremeyeceği şeylerdir; bunlar SF-02 ve SF-04 kilitlerinde kalır. YZ'nin kararı satış izninin **bir** girdisidir, tamamı değil.

5 Model güncellenince ne yapılır? EK SORU

Yeni model bir yazılım değişikliğidir (EP 14 Change Management). Önce aynı doğrulama veri setinde eski modelle karşılaştırılır; yanlış OK oranı artmışsa yüklenmez. Eşik yeniden doğrulanır, sürüm ve hash kaydedilir, eski modele geri dönüş yolu hazır tutulur. Güncelleme uzaktan değil, LAB4'teki süreli bakım prosedürüyle yapılır.

6 Operatör onayı neyi aşabilir, neyi aşamaz? EK SORU

Aşabilir: YZ'nin "emin değilim" ya da "RED" kararını, kabı kendisi görüp düzelttiğinde. **Aşamaz:** sıcaklık, yıkama ve kapak kilitlerini; bağımsız kap sensörünün "kap yok" kararını. Her operatör onayı kişisel hesapla kaydedilir; sık onay verilen durumlar modelin zayıf olduğu yeri gösterir.

7 YZ tamamen devre dışıyken otomat nasıl çalışır? EK SORU

Bugünkü otomat da kamerasız çalışıyor. YZ kapalıyken dolum, önerilen kap sensörü ve operatör kontrolüne döner. YZ kapalıyken otomatın **daha az güvenli değil, daha az otomatik** çalışması gerekir. Bu, YZ'nin emniyet zincirinin dışında tasarlandığının en basit testidir: kamera kablosu çekildiğinde güvenli davranış değişmemelidir (EP 15 doğrulama maddesi).

Varsayımlar

Kamera ve YZ işlevi **yalnız eğitim senaryosudur**; otomatın envanterine eklenmedi (Makine profili). Model geliştirilmedi, confidence ölçülmedi, test yapılmadı. PLr/SIL atanmadı.

Bu föyün çıktısı **AI Fail-Safe Decision** → Evidence Pack **EP 03 Safety Functions + EP 15 Verification/Test** başlığına oturur. Durum: **Taslak**.